TUNGSTEN SUPPLY CHAIN COMPLIANCE PLATFORM

Revised Project Specification — Version 2.3 (US Edition)

Document Status	DRAFT — For CTO & Compliance Lead Review	**Version**	2.3 (US Edition)
Date	March 2026	**Scope**	United States operations only
Classification	Confidential — Internal Use Only	**Status**	DRAFT
Changes from v2.2	Decision D3 resolved: industry-standard cross-validation tolerance values defined for all 12 event types. FR-008 updated with per-event tolerance table. Section 8.2 and Section 17 updated accordingly. Ref: D3-DEFAULTS-v1.0, 16 March 2026. | v2.3 gap analysis applied — 18 changes: CMMC 2.0 (Section 7.5, FR-079, FR-080), ITAR/EAR (Section 7.6, FR-081, FR-082), FedRAMP posture (NFR-14), API deprecation policy (FR-054a), offline encryption (FR-055a), framework count correction (H5), 11 annotated action items with owners and deadlines (C2, C3, H2, H3, M2–M6, L3, L4). Author: Claude, 17 March 2026.		

Derived from the System Architecture Basis Document. Implementation details and architecture excluded. Incorporates US-only scope restriction applied March 2026.

1. Executive Summary

This specification defines requirements for a digital platform that provides end-to-end, auditable custody tracking and regulatory compliance documentation for tungsten supply chains operating within the United States. The platform enables manufacturers, suppliers, traders, and auditors to demonstrate compliance with United States conflict-mineral regulations without ambiguity or manual documentation burden.

The platform is the authoritative system of record for custody events, compliance status, and supporting documents across the full tungsten lifecycle — from mine extraction through to end-of-life re-entry. It must produce legally defensible compliance packages on demand, independently verifiable by any authorised third party.

Scope Restriction — US Only (v2.2/v2.3):

This version restricts platform scope to United States operations. Removed from scope: GDPR compliance obligations, EU data residency configuration, Data Protection Officer designation, ILO international labour standards (replaced by US federal and state law equivalents), multilingual document storage, and cross-border EU data transfer controls. Data residency is fixed to US Azure regions.

■ Internal Audit — Review Note

- The specification must establish clear ownership and accountability for each compliance requirement and document class.
- A defined escalation path is required: the spec must state who is notified when a compliance check fails and within what timeframe.
- The definition of 'authoritative record' must be formalised: the platform must be unambiguously designated as the system of record, and any manual overrides must be logged with justification.

■ Computer Scientist — Review Note

- FR-XXX identifiers are applied throughout Section 5. Each identifier must be linked to a corresponding test case before any build activity begins.
- Event schema versioning (Section 8.4) and concurrency controls (Section 8.5) must be reviewed by the Backend Lead before the data model is finalised.
- The compliance rule authoring model (Section 5.9) must be agreed with the Compliance Lead before the rule engine is built.

■ CEO — Review Note

- Section 15 (Commercial Framework) addresses the commercial model for US market operations.
- The supplier value proposition must be defined before supplier onboarding contracts are signed.
- The US-only scope simplifies the legal compliance posture significantly and removes the primary DRAFT blocker.

2. Project Objectives

The platform shall achieve the following objectives, in priority order:

#	Objective	Success Condition
OBJ-01	**Regulatory Compliance**	Any authorised user can produce a complete, submission-ready DFARS declaration, Section 232 readiness package, or Form SD support package within 30 minutes of request, with zero manual document assembly.
OBJ-02	**Immutable Chain of Custody**	Every custody event is permanently recorded with tamper-evident proof. Any retrospective alteration is detectable and attributed to a named user with a stated justification.
OBJ-03	**Multi-Party Visibility**	Suppliers, buyers, and auditors access the same underlying data through role-appropriate views, eliminating version disputes and conflicting documentation.
OBJ-04	**Automated Compliance Monitoring**	The system continuously evaluates each active batch against all applicable regulatory frameworks and flags non-conformances within 24 hours of a triggering event.
OBJ-05	**Audit Readiness**	A full audit dossier for any batch — including all custody events, supporting documents, third-party assay results, and blockchain verification proofs — is retrievable within 4 business hours.
OBJ-06	**Third-Party Verifiability**	Any external party with a QR code or batch identifier can independently confirm the integrity of a compliance package without requiring platform access or credentials.
OBJ-07	**Commercial Sustainability**	The platform generates sufficient subscription revenue to cover operational costs within 18 months of Phase 2 go-live, at a defined minimum US tenant base.

3. Scope

3.1 In Scope

- Custody event capture and validation for all twelve defined event types across the tungsten supply chain lifecycle.
- Automated compliance checking against ~~nine regulatory frameworks~~nine named regulatory frameworks plus a configurable Custom Rules layer (see Section 5.2).
- Generation of five compliance document package types on demand.
- Document management: upload, versioning, access control, lifecycle, and retrieval (Section 5.7).
- Search and retrieval across custody events and compliance documents (Section 5.8).
- Compliance rule authoring and version management (Section 5.9).
- Partner API for Enterprise tenant integration (Section 5.10).
- Offline and degraded-mode event capture for suppliers with intermittent connectivity (Section 5.11).
- Role-based portals for suppliers, buyers, auditors, compliance officers, and administrators.
- Tamper-evident anchoring of custody events and document hashes to an external immutable ledger.
- Integration with accredited US laboratory data providers, in-transit tracking devices, and CBP ACE customs systems.
- Automated alerting and notification for compliance exceptions, certificate expiry, and event anomalies.
- Reporting across supply chain performance, compliance status, and batch provenance.
- Incident response capability (Section 7.4).

3.2 Out of Scope

- Physical logistics operations or transport booking.
- Financial transaction processing or invoicing.
- Management of supply chains for commodities other than tungsten (unless explicitly extended in a future phase).
- Internal ERP or MES system replacement for any supply chain participant.
- Customs submission on behalf of any party (the platform provides supporting data only).
- EU or non-US data residency, GDPR compliance obligations, or cross-border EU data transfer controls.
- AI-assisted anomaly detection or predictive compliance scoring (see Section 16 for position statement).
- Third-party auditor certification issuance (the platform supports auditor verification but does not issue certificates of compliance).
- Non-US regulatory frameworks not listed in Section 5.2.

4. Stakeholders and User Groups

Stakeholder	Role	Primary Needs
Tungsten Suppliers	*Data Providers*	Simple event submission, document upload, visibility of own compliance status. Batch-level provenance certificate for use in their own customer relationships.
Buyers / Manufacturers	*Compliance Recipients*	Confidence that upstream supply is compliant; on-demand package generation for own US regulatory filings. ERP integration via Partner API (Enterprise tier).
External Auditors	*Independent Verifiers*	Read-only access to full audit dossiers; ability to verify blockchain proofs without platform login. Documented audit trail of their own verification activities.
Internal Compliance Teams	*Rule Managers*	Ability to configure compliance rules, review exceptions, approve escalations. Rule authoring without code deployment.
Regulatory Bodies	*Occasional Recipients*	Receive generated packages; no direct platform access required.
Platform Administrators	*System Operators*	User management, integration health monitoring, system configuration.
Platform Operator (Commercial)	*Business Owner*	Tenant onboarding, subscription management, regulatory change management, SLA compliance monitoring.

5. Functional Requirements

All functional requirements carry a unique FR-XXX identifier. Each identifier must be linked to a test case before the requirement enters the build queue.

5.1 Custody Event Management

The system shall capture, validate, and record the following twelve custody event types as distinct, structured data objects:

No.	Event Type	Mandatory Data Elements
1	**Mine Extraction**	Mine identifier, GPS coordinates, extraction date, quantity (kg), mineralogical certificate reference, mine operator identity.
2	**Concentration / Beneficiation**	Facility identifier, input batch reference(s), output batch reference, processing date range, mass balance data, facility compliance status.
3	**Trading / Ownership Transfer**	Transferring party, receiving party, transfer date, legal title document reference (legal transfer), physical custody transfer date and custodian identity (physical transfer). Legal and physical transfer are recorded as separate fields.
4	**Laboratory Assay**	Accredited laboratory identifier, sample reference, assay date, results (grade, purity, contaminants), certificate hash.

No.	Event Type	Mandatory Data Elements
5	**Primary Processing (Smelting)**	Smelter identifier, RMAP conformance status, input batch(es), output product reference, processing date, mass balance.
6	**Secondary Processing (Conversion)**	Facility identifier, conversion type, input reference, output reference, date range, product specification.
7	**Warehousing / Storage**	Warehouse identifier, location, receipt date, quantity, storage conditions reference, custodian identity.
8	**Export Clearance**	Origin country, destination country, export declaration reference, CBP ACE authority, date, HS code.
9	**In-Transit Monitoring**	Tracking device identifier, route waypoints with timestamps, GPS coordinates, departure and arrival confirmations, any anomaly flags.
10	**Import Clearance**	Port of entry, import declaration reference, CBP ACE authority, date, any Section 232 exclusion or tariff reference.
11	**Customer Delivery**	Delivery address, recipient identity, delivery date, signed receipt reference, final quantity.
12	**End-of-Life / Recycling Re-entry**	Collector identity, scrap type, quantity, collection date, new batch identifier, provenance break acknowledgement. First-class high-integrity event with its own validation rules distinct from other event types.

For every event type the system shall additionally record: submitting user identity, submission timestamp, GPS coordinates (where applicable), facility identifier, document hash(es) for all attached supporting documents, event schema version, and a tamper-evident anchor reference.

FR-001 The system shall validate all mandatory fields for each event type at submission time and reject non-conforming submissions with a field-level error message identifying each failing field.

FR-002 The system shall enforce idempotency: submitting the same event twice shall not create duplicate records. A deterministic event identifier derived from key fields shall be computed and checked before persistence.

FR-003 The system shall record all custody events as immutable records. Corrections shall create a new linked record referencing the original; the original shall be preserved with all original field values.

FR-004 The system shall handle events submitted out of chronological order. Logical sequence violations (e.g. export clearance before import clearance) shall be flagged for review without rejecting the record.

FR-005 The system shall support split-batch operations: when a consignment is divided, sub-batch identifiers shall be created with parent-child references. The custody chain shall remain coherent and independently traceable at the sub-batch level.

FR-006 Disputed events shall be assigned Disputed status and held until resolved by an authorised Compliance Officer. The system shall not silently overwrite a conflict between supplier-submitted and buyer-submitted event data.

FR-007 GPS coordinates shall be validated against plausible ranges. Coordinates inconsistent with the stated facility country shall trigger a review flag.

FR-008 Mass balance shall be checked across processing events. Output quantities exceeding input quantities by more than the configured tolerance threshold shall be flagged for review. Cross-validation tolerance values are defined per event type in the table below (Decision D3 — resolved 16 March 2026, ref: D3-DEFAULTS-v1.0):

No.	Event Type	Qty Tol (%)	Date Tol (days)	Mass Bal (%)	Industry Source
1	Mine Extraction	**1.0**	*N/A*	*N/A*	*ASTM E1108 / ISO 13909*
2	Concentration / Beneficiation	**2.0**	**30**	**5.0**	*ASTM E1108 · OECD DDG Annex II*
3	Trading / Ownership Transfer	**0.5**	**7**	*N/A*	*LBMA Good Delivery · CBP ACE*
4	Laboratory Assay	*N/A*	**14**	*N/A*	*ISO 17025 accreditation turnaround*

No.	Event Type	Qty Tol (%)	Date Tol (days)	Mass Bal (%)	Industry Source
5	Primary Processing (Smelting)	1.5	30	10.0	*RMAP Smelter Audit Reports · RMI*
6	Secondary Processing (Conversion)	1.5	30	8.0	*ASTM B777 · facility recovery rates*
7	Warehousing / Storage	0.5	3	*N/A*	*ASTM E1108*
8	Export Clearance	2.0	5	*N/A*	*CBP ACE / 19 CFR 141*
9	In-Transit Monitoring	*N/A*	2	*N/A*	*GPS/IoT telemetry standards*
10	Import Clearance	2.0	7	*N/A*	*CBP ACE / 19 CFR 141*
11	Customer Delivery	0.5	14	*N/A*	*ASTM E1108*
12	**End-of-Life / Recycling Re-entry**	1.0	14	3.0	*OECD DDG · RMAP recycled content*

Qty Tol = maximum percentage difference between linked event quantities. Date Tol = maximum days between linked event dates before flagging. Mass Bal = maximum percentage by which output mass may exceed input mass. N/A = tolerance type not applicable at this event stage. Event 12 carries the tightest mass balance threshold; the provenance break acknowledgement field carries zero tolerance and is mandatory with no override. These values are stored in compliance-config/tolerance-rules.json and are subject to Compliance Lead sign-off for any future amendment (see FR-065).

FR-009 The system shall record the event schema version active at the time of submission alongside each custody event record, to support schema evolution without altering historical records.

■ Supply Chain Expert — Review Note

- Event Type 3 explicitly distinguishes legal title transfer from physical custody transfer as separate recorded fields. This must be reflected in the data model and the UI form for this event type.
- Event Type 12 (End-of-Life / Recycling Re-entry) must be treated as a first-class, high-integrity event. The provenance break acknowledgement is a critical compliance record and must be captured as a mandatory, explicitly confirmed field.
- Split-batch rules (FR-005) must be accompanied by test scenarios covering: equal split, unequal split, partial shipment with remainder in storage, and sub-batch re-aggregation.

5.2 Compliance Rule Engine

The system shall automatically evaluate each batch and its associated custody events against the following regulatory frameworks and maintain a continuously updated compliance status per batch:

Framework	Full Name	Key Check Requirements	Output Indicator
DFARS 7008	Defense Federal Acquisition Regulation Supplement 252.225-7008 (Prime Contractors)	Covered-country origin flag; smelter list conformance; declaration completeness. Obligations specific to prime contractors.	*Compliant / Non-Compliant / Requires Review*
DFARS 7009	Defense Federal Acquisition Regulation Supplement 252.225-7009 (Sub-Contractors)	Covered-country origin flag; smelter list conformance; sub-contractor specific obligation set. Distinct from 7008.	*Compliant / Non-Compliant / Requires Review*
Section 232	US Section 232 Steel & Aluminum	Processing-country verification; exclusion request reference where applicable.	*Eligible / Potentially Subject to Tariff / Exclusion Pending*

Framework	Full Name	Key Check Requirements	Output Indicator
	Tariffs (tungsten derivatives)		
RMAP	Responsible Minerals Assurance Process (RMI)	Smelter conformance status from current quarterly list; certification expiry date.	*Conformant / Listed-Not-Conformant / Not Listed*
OECD DDG	OECD Due Diligence Guidance — Minerals (Annex II Risk Flags)	Risk flag scoring across six risk categories; source country classification.	*Low / Medium / High Risk Score*
Form SD	Dodd-Frank Section 1502 — Conflict Minerals Report	3TG applicability determination; supply chain description completeness.	*In Scope / Out of Scope / Indeterminate*
Labour Compliance	Applicable US federal and state labour standards (FLSA, OSHA, NLRA, and state equivalents)	Certificate currency; issuing body validated against approved-body register; coverage scope. Unrecognised issuing body triggers review flag, not automatic pass.	*Current / Expiring (30-day) / Expired*
Environmental	Applicable US environmental certification standards (EPA standards and equivalents)	Certificate currency; facility audit date.	*Current / Expiring / Expired*
Chain of Custody CoC	Industry CoC standard (e.g. RMI Chain of Custody)	Completeness of event chain; no unresolved gaps.	*Complete / Gap Identified / Incomplete*
Custom Rules	Buyer- or contract-specific requirements	Configurable by compliance team; rule version-controlled; isolated per buyer contract.	*Pass / Fail / Waived*

■ Framework Count Note (H5)

The nine named regulatory frameworks are: DFARS 7008, DFARS 7009, Section 232, RMAP, OECD DDG, Form SD, Labour Compliance, Environmental, and Chain of Custody CoC. Custom Rules are tenant-configured and are not subject to regulatory update SLAs. Custom Rules are isolated per buyer contract (FR-012) and are not counted in the nine named frameworks for the purposes of regulatory watch obligations (FR-065) or SLA commitments (FR-066).

FR-010 Each compliance assessment record shall store the exact version of the rule set applied at the time of evaluation. A change to any regulatory framework rule shall not retroactively alter the compliance status of historical records.

FR-011 DFARS 252.225-7008 and 252.225-7009 shall be implemented as separate, independent compliance check rows with distinct obligation sets. They shall not be conflated in any assessment record, user interface, or generated document.

FR-012 Custom buyer rules shall be isolated per contract. A rule applicable to one buyer's batches shall not affect any other buyer's compliance assessments. Isolation shall be verified by a cross-buyer test scenario in every release.

FR-013 The approved-body register for labour compliance certificate validation shall be maintained by the compliance team, versioned, and effective-dated. The version active at assessment time shall be stored alongside each assessment record.

⚠ REQUIRED BEFORE PHASE 2 BUILD — M2 (FR-013 Labour Compliance)

The Compliance Lead must define before Phase 2 build begins: (1) what constitutes a valid US Labour Compliance certificate (candidates: OSHA 300 log, third-party audit by WRAP or equivalent US-recognised body, state labour agency certification); (2) which US-accredited bodies qualify for the approved-body register; and (3) whether supplier self-certification is permissible under any circumstances. This definition must be appended to the approved-body register configuration before the Labour Compliance framework enters the build queue.

FR-014 The system shall re-evaluate all affected batch compliance statuses automatically within 5 business days of a new RMAP quarterly list being ingested. A named change log report shall record which batches changed status, from what to what, and on which date.

⚠ REQUIRED BEFORE PHASE 2 BUILD — M3 (Environmental Framework Gap)

The Environmental framework in the Section 5.2 table does not name specific EPA programmes, an approved-body register, or which event types trigger environmental checks. The Compliance Lead must define these before the Environmental framework is built in Phase 2, mirroring the FR-013 structure for Labour Compliance. This definition must be documented and appended to this specification before the Environmental framework enters the build queue.

■ Compliance & Legal Expert — Review Note

- DFARS 7008 and 7009 are separate rows in the framework table. The rule engine must implement these as independent evaluation paths.
- The OECD risk-scoring methodology must be version-controlled. The version identifier must be stored in every compliance assessment record that uses an OECD-derived score.
- Labour compliance is now scoped to US federal and state law. The approved-body register must reflect US-accredited bodies only.
- Custom buyer rule isolation must be verified in testing with explicit cross-buyer scenarios. A rule leak between buyer tenants is a serious compliance failure.

5.3 Document Generation

Package Type	Contents	Trigger
DFARS Declaration Package	Supplier representation statements, smelter list extracts, country-of-origin certifications, conflict-mineral declaration form.	*On-demand by buyer or compliance team; auto-generated on annual cycle.*
Section 232 Readiness Package	Processing-country evidence, tariff classification documentation, exclusion request support data.	*On-demand when batch destined for US import.*
Form SD Support Package	3TG applicability determination, supply chain description, due-diligence process documentation, risk assessment summary.	*On-demand for annual SEC filing support.*
Material Passport	Full provenance summary, custody event log, compliance status summary, QR code linking to blockchain verification.	*On-demand for any completed batch; optionally delivered with physical shipment.*
Audit Dossier	Complete document set including all event records, supporting documents, laboratory certificates, blockchain proofs, compliance assessment history.	*On-demand by auditor role or compliance team; must be available within 4 business hours.*

FR-015 All generated compliance document packages shall include a document generation timestamp, the compliance rule set version applied, and the platform version identifier.

FR-016 The audit dossier shall include a documented record of all blockchain verification calls made during its assembly, including the verification result and timestamp of each call.

5.4 Tamper-Evident Anchoring

FR-017 The cryptographic hash of each custody event record and each supporting document shall be anchored to the external ledger at the time of creation or upload. The hashing algorithm shall be SHA-256 as a minimum. A documented upgrade path shall exist for when SHA-256 is deprecated.

FR-018 The full content of events and documents shall not be stored on the external ledger. Only the hash and a timestamp shall be anchored.

FR-019 Any authorised party shall be able to verify the integrity of a compliance package using only a QR code or batch identifier, without requiring platform credentials. The verification response shall return only: verification

status, anchored timestamp, batch reference, and provider name. No personal data or commercial data shall be returned.

FR-020 The platform shall support migration between anchoring providers without loss of historical verification capability. The anchoring provider used for each record shall be stored as metadata alongside the hash.

FR-021 The original hash shall be retained when a document is amended or superseded. The superseding version shall receive a new hash. Both hashes shall be independently queryable.

5.5 Alerting and Notification

FR-022 The system shall issue automated alerts when: a compliance check fails for any active batch; a certificate or accreditation is within 30 days of expiry; a custody event creates a logical sequence anomaly; an integration data feed fails to update within its defined refresh window.

FR-023 Each alert shall include: the affected batch identifier, the nature of the non-conformance, the applicable regulatory framework, the recommended action, and the escalation contact.

FR-024 Alert escalation rules shall be configurable by the Platform Administrator. An unacknowledged alert shall auto-escalate to the designated senior Compliance Officer after 48 hours.

FR-025 Alerts shall be delivered via in-platform notification and configurable external channels (email at minimum). Delivery failure shall be logged to the audit trail and the escalation contact notified via an alternative channel.

5.6 Reporting

FR-026 The system shall provide a real-time compliance dashboard displaying the aggregate compliance status of all active batches, broken down by regulatory framework.

FR-027 Batch-level provenance maps shall display the full custody chain geographically.

FR-028 Reports shall be exportable in at least PDF and CSV formats. All reports shall clearly state the data extraction timestamp and the version of compliance rules applied.

FR-029 The RMAP re-evaluation change log shall be a named, retained, auditable report type in the reporting module. It shall be accessible to Compliance Officers and Auditors.

5.7 Document Management

FR-030 Suppliers shall be able to attach documents to custody events at submission time or subsequently. Each attachment shall be associated with the specific event, the submitting user identity, and the submission timestamp.

FR-031 When a supplier supersedes an incorrect or outdated document, the original shall be preserved with its original hash. The superseding document shall receive a new hash and a new version record. Both shall remain queryable. The supersession shall be logged with the user identity and justification. A supersession without justification shall not be permitted.

FR-032 Document access control shall enforce: Suppliers may access only their own submitted documents. Buyers may access documents shared with them via a custody event but may not download or redistribute them without the submitting supplier's explicit consent configuration. Auditors may access all documents within an assigned audit dossier. Compliance Officers may access all documents. Document access events shall be included in the audit log.

FR-033 The platform shall accept the following document upload formats: PDF, JPEG, PNG, and structured data files (CSV, XML) for laboratory results. Maximum file size per document: 50 MB.

FR-034 Document SHA-256 hashes shall be computed client-side at the point of upload and verified server-side on receipt. A mismatch shall reject the upload with a clear error message.

FR-035 Document hashes shall be re-verified on every retrieval. A hash mismatch detected at retrieval shall trigger an immediate alert to the Platform Administrator and flag the affected document as potentially tampered.

FR-036 The platform shall enforce the data retention policy for documents: all documents shall be retained for a minimum of 10 years from the date of the associated custody event. Hard deletion shall be blocked until this period has elapsed.

FR-037 The platform shall provide a data subject access and correction workflow for platform users whose personal data is held in document metadata. This workflow shall allow pseudonymisation of personal data fields on request, while preserving the document content and hash in their immutable form. This workflow is scoped to US privacy law requirements applicable at the time of deployment.

FR-038 The platform shall provide a document search capability allowing users to locate documents by: document type, associated batch identifier, event type, submission date range, and issuing organisation. Search results shall respect the access control rules defined in FR-032.

■ Internal Audit — Review Note

- FR-031 (document supersession) requires justification from the submitting user. A supersession without justification shall not be permitted.
- FR-037 (data correction workflow) is scoped to US privacy law. The Compliance Lead must confirm which US privacy statutes apply to the platform's tenant base before deployment.
- Document access logs (who accessed which document and when) must be included in the audit log under FR-032. This is required for DFARS audit defensibility.

5.8 Search and Retrieval

FR-039 The system shall provide full-text search across custody events and compliance documents for users with Auditor or Compliance Officer roles.

FR-040 Search shall support the following filters: batch identifier, event type, event date range, submitting supplier, compliance framework, compliance status, and document type.

FR-041 Search results shall respect all role-based and tenant-based access control rules. A search query shall never return results from a different tenant or from documents the requesting user is not authorised to view.

FR-042 Search indices shall be updated within 60 seconds of a custody event being created or a document being uploaded.

FR-043 The audit dossier retrieval function shall support lookup by: batch identifier, batch date range, supplier identity, and compliance status at a given date.

5.9 Compliance Rule Authoring Model

FR-044 Each compliance rule shall be defined as a named, versioned rule set stored in the platform database. A rule set shall contain: framework identifier, rule version, effective date, expiry date (if applicable), and the rule logic in a format agreed between the CTO and Compliance Lead.

⚠ ACTION — M4 (Rule Authoring Format)

A rule authoring format workshop must be scheduled before Week 3 of the project schedule. Candidate formats: (1) structured database records with UI form builder; (2) YAML DSL evaluated at runtime; (3) compiled rule class deployed via Compliance Rule Update pipeline. Output must be a signed Rule Authoring Format Decision Record by CTO and Compliance Lead. Without this decision, the compliance rule engine sprint cannot start.

FR-045 A new rule set version shall be deployable by a Compliance Officer via the platform UI without requiring a code deployment. Deploying a new rule set version shall not trigger retroactive re-evaluation of historical compliance assessments.

FR-046 Each rule set version shall be immutable once deployed. Corrections shall require a new version to be created. The version history shall be fully auditable.

FR-047 Custom buyer rules shall be defined and stored in an isolated namespace per buyer contract. The custom rule authoring interface shall enforce that a rule created for Buyer A cannot be applied to Buyer B's batches.

FR-048 The platform shall provide a rule test environment in which a proposed rule set version can be validated against a defined set of historical batch scenarios before being deployed to production.

5.10 Partner API (Enterprise Tier)

FR-049 The Partner API shall expose the following capabilities as authenticated, versioned REST endpoints: batch and custody event read (all event types), compliance status read (all frameworks), compliance package request and retrieval, alert subscription via webhook, and document metadata read.

FR-050 The Partner API shall not expose write endpoints for custody event creation in Phase 1. Write access shall be a Phase 2 capability, pending security review.

FR-051 All Partner API endpoints shall be documented in an OpenAPI 3.0 specification, published via the APIM Developer Portal for Enterprise tenants.

FR-052 Partner API rate limits: 1,000 read requests per minute per tenant subscription; 100 write requests per minute per tenant subscription. Rate limit headers returned on every response. HTTP 429 returned on breach.

FR-053 Partner API access shall require a dedicated API key scoped to the tenant. API keys shall be rotatable by the tenant administrator without service interruption. All API key usage shall be logged to the audit trail.

FR-054 The Partner API shall support webhook delivery for compliance status change events. Webhook delivery failures shall retry with exponential backoff for 24 hours before alerting the tenant administrator.

FR-054a The platform shall support at least one prior major Partner API version simultaneously with the current version. Deprecation of a major version shall be communicated to all affected Enterprise tenants a minimum of 90 days in advance via the APIM Developer Portal and direct email notification. A sunset date shall be published at the time of deprecation notice.

5.11 Offline and Degraded-Mode Operation

FR-055 The Supplier Portal shall support offline custody event capture: a supplier shall be able to complete and locally store a custody event submission when internet connectivity is unavailable.

FR-055a The Supplier Portal shall encrypt offline-captured event data at rest on the local device using AES-256 or equivalent. The encryption key shall be derived from the user's authenticated session and shall not persist after logout. An offline event store that cannot be decrypted by the authenticated user on next login shall be discarded and not submitted to the platform.

FR-056 Offline-captured events shall be automatically submitted to the platform when connectivity is restored. The submission shall include an 'offline-captured' flag and the local capture timestamp.

FR-057 Offline-captured events shall be subject to the same mandatory field validation, idempotency checks, and four-eyes approval requirements as online submissions.

FR-058 The platform shall remain available in read-only mode for all authenticated users when the compliance rule engine or document generator is unavailable. A visible service status indicator shall inform users of affected capabilities.

FR-059 Integration failures (lab APIs, customs APIs, RMAP list) shall not cause the platform to reject custody event submissions. Affected features shall degrade gracefully with a visible 'data last updated' timestamp.

6. Non-Functional Requirements

ID	Category	Requirement
NFR-01	**Availability**	The platform shall be available 99.5% of the time, measured monthly, excluding agreed maintenance windows.
NFR-02	**Performance**	Compliance package generation shall complete within 5 minutes for any single batch (p95 under 200 concurrent users). Dashboard loading shall complete within 3 seconds (p95). If generation is queued beyond 4 minutes, the requesting user shall be notified with an estimated completion time.
NFR-03	**Scalability**	The platform shall handle a minimum of 500 concurrent users and 10,000 custody events per day without performance degradation. This figure shall be validated against current batch volumes and a 3-year growth projection before being accepted as a contractual SLA.
NFR-04	**Data Retention**	All custody event records, compliance assessments, and supporting document hashes shall be retained for a minimum of 10 years from event date, in line with DFARS record-keeping requirements.
NFR-05	**Audit Logging**	All user actions that create, modify, or delete data shall be logged with: user identity, timestamp, action type, affected record identifier, and before/after state. Logs shall be append-only at the data store level and retained for 7 years.
NFR-06	**Accessibility**	User interfaces shall conform to WCAG 2.1 Level AA. The Supplier Portal shall be functional on a smartphone browser with a 3G connection.
NFR-07	**Language**	The platform shall support data entry and display in English. Supplier-submitted documents may be uploaded in any language; the platform shall store them as-is without requiring translation. No multilingual UI is required.
NFR-08	**Recovery**	Recovery Point Objective (RPO): 1 hour. Recovery Time Objective (RTO): 4 hours.
NFR-09	**Rate Limiting (Public Endpoint)**	The public QR verification endpoint shall be rate-limited to 60 requests per minute per IP address. Bot protection shall be applied. Denial-of-service on this endpoint shall not cascade to platform availability.

ID	Category	Requirement
NFR-10	Search Performance	Full-text search queries shall return results within 3 seconds (p95) for indices containing up to 1 million custody event records.
NFR-11	API Performance	Partner API endpoints shall respond within 500ms (p95) for read operations and 2,000ms (p95) for write operations under normal load.
NFR-12	Offline Sync	Offline-captured events shall be synchronised to the platform within 60 seconds of connectivity being restored, subject to server processing capacity.
NFR-13	Data Residency	All tenant data shall be stored within United States Azure regions. US East shall be the primary region. US West shall be the secondary disaster recovery region. No data shall be written to non-US Azure regions.
NFR-14	FedRAMP Posture	The platform operates on Azure Commercial regions (US East primary, US West secondary) in Phase 1. The platform does not hold FedRAMP Moderate or High authorisation in Phase 1. This is a known limitation that may restrict sales to DoD prime contractor segments whose contracts require FedRAMP-authorised cloud services for CUI. The CTO shall assess FedRAMP Moderate authorisation feasibility as part of Phase 2 commercial planning.

7. Security and Access Requirements

7.1 Access Control

Role	Access Permissions
Supplier	Submit and view own custody events and documents. View own batch compliance status. Upload documents and manage document versions for own submissions. No access to other parties' data.
Buyer	View custody events and compliance status for batches in their supply chain. Request and download compliance packages. Access documents shared with them. Cannot modify event records or redistribute documents without supplier consent configuration.
Auditor	Read-only access to full audit dossiers for assigned batches. Full-text search within assigned dossiers. Cannot modify any records. Can verify blockchain proofs. Verification activities logged to audit trail.
Compliance Officer	Configure compliance rules. Review and resolve exception flags. Approve escalated alerts. View all batches. Manage approved-body register. Deploy new rule set versions. Execute data correction workflow.
Platform Administrator	User management. Integration configuration. System health monitoring. Alert channel configuration. API key management. No business data modification access.

7.2 Authentication and Data Security

- All users shall authenticate via multi-factor authentication (MFA). Single-factor access is not permitted for any role. MFA enforcement shall be applied at the identity provider level.
- All data in transit shall be encrypted using TLS 1.2 or higher. All data at rest shall be encrypted using AES-256 or equivalent.
- API integrations with third-party laboratory and customs systems shall use mutual TLS or equivalent. Shared secrets shall not be stored in source code or configuration files. All secrets shall be managed via a dedicated secrets vault solution.
- All tenant data shall be stored within US Azure regions (NFR-13). No cross-border data transfers are required or permitted.
- The platform shall undergo independent penetration testing at least annually, with critical findings remediated within 30 days and high findings within 60 days.
- Supplier data isolation shall be enforced at the data layer (row-level security), not only at the application layer. A privilege-escalation bug shall not expose one supplier's data to another.

7.3 Data Classification Schema

Level	Examples	Access Control	Encryption
Public	QR verification result, public batch reference	Unauthenticated (rate-limited). WAF-protected.	TLS in transit. Standard at rest.
Internal	Aggregate compliance dashboard, anonymised statistics	Authenticated tenant users. Any role.	TLS + AES-256 at rest.
Confidential	Custody event records, assay results, compliance assessments, audit logs	Authenticated. Role-scoped RBAC. RLS at SQL layer. Access logged.	TLS + AES-256 at rest + storage encryption.
Restricted	Supplier commercial documents, export-controlled references, personal data fields	Named-role access only. Tenant-owner consent for cross-party access. BYOK option.	TLS + AES-256 + optional BYOK. Access alerts. Immutable audit trail.

7.4 Incident Response

FR-060 The platform shall maintain a defined incident response plan covering: detection of a potential breach, initial triage, containment, evidence preservation, root cause analysis, and recovery. The plan shall be documented, version-controlled, and reviewed annually.

FR-061 The platform shall detect and alert on anomalous data access patterns (bulk data export, access from unexpected locations, unusual query volumes) within 30 minutes of the anomaly occurring.

FR-062 In the event of a confirmed or suspected personal data breach, the platform operator shall produce a breach notification report within 4 hours of confirmation, containing: categories of data affected, approximate number of individuals affected, likely consequences, and measures taken or proposed.

FR-063 The Platform Operator shall designate a named data protection contact responsible for privacy compliance and breach response coordination.

FR-064 A data correction and pseudonymisation workflow shall be available to Compliance Officers for processing user access and correction requests under applicable US privacy law.

■ Security Expert — Review Note

- FR-061 (anomaly detection) requires baseline traffic profiling during the first 30 days of production operation before alert thresholds can be set.
- FR-062 (breach notification in 4 hours) supports US state breach notification timelines. The 4-hour internal report provides adequate time for legal review before external notification.
- US state privacy laws (CCPA, CPRA, and state equivalents) may impose additional obligations depending on the tenant base. The Compliance Lead must confirm applicable state laws before go-live.

7.5 CMMC 2.0 Compliance Posture

The platform handles Controlled Unclassified Information (CUI) for DoD contractors. CMMC 2.0 Level 2 (effective December 2024) requires a C3PAO third-party assessment, not just self-attestation. Buyer tenants who are DoD contractors may be unable to include this platform in their CMMC affirmation without a documented platform posture.

FR-079 The Platform Operator shall complete a CMMC 2.0 Level 2 gap assessment against all 110 NIST SP 800-171 controls before Phase 1 go-live. The gap assessment shall be documented and made available to buyer tenants on request.

FR-080 The CTO shall decide before Week 4 of the project schedule whether to pursue C3PAO third-party assessment or to proceed with annual self-attestation. This decision shall be documented in writing as an annex to this specification.

⚠ CMMC Review Note (C1)

CMMC posture decision (FR-080) is a pre-APPROVED-status action jointly owned by CTO and Compliance Lead. Decision deadline: Week 4 of project schedule. This decision must be documented before this specification is promoted from DRAFT to APPROVED.

7.6 ITAR / EAR Export Control Assessment

Tungsten is used in defence applications subject to ITAR (22 CFR 120–130) and EAR (15 CFR 730–774). Section 11.1 restricts storage of export-controlled document content, but no mechanism exists to identify or flag export-controlled material at the event or document level. This section establishes requirements to address that gap.

FR-081 The platform shall support an export control flag field on custody events and document uploads. Where a custody event or document is marked as export-controlled, the platform shall automatically apply Restricted data classification and notify the designated Compliance Officer before that record or document is shared with any other party.

FR-082 The Compliance Lead shall complete a formal ITAR/EAR applicability assessment before Phase 2 go-live. The assessment shall be documented in writing and reviewed by Legal counsel before any export-controlled supply chain data is processed by the platform.

8. Data Requirements

8.1 Data Integrity

- All custody event records shall be immutable once anchored. Corrections shall create a new, linked record referencing the original, with the original preserved.
- Document hashes shall be computed at the point of upload and verified on each retrieval; a mismatch shall trigger an immediate alert.
- Batch identifiers shall be unique across the entire platform lifetime; identifier reuse is not permitted even for archived batches.

8.2 Data Quality

- Mandatory fields for each event type shall be validated at submission; records failing validation shall be rejected with a clear, actionable error message identifying each failing field.
- GPS coordinates shall be validated against plausible ranges; coordinates inconsistent with the stated facility country shall trigger a review flag.
- Mass balance shall be checked across processing events; output quantities exceeding input quantities by more than the configured tolerance threshold shall be flagged.
- Cross-validation discrepancy thresholds (quantity tolerance %, date tolerance in days, mass balance threshold %) are defined per event type in FR-008 and in compliance-config/tolerance-rules.json (Decision D3, resolved 16 March 2026, ref: D3-DEFAULTS-v1.0). These values are version-controlled and require Compliance Lead sign-off for any future amendment.

8.3 External Data Feeds

- The RMAP quarterly smelter conformance list shall be ingested and applied within 5 business days of official publication; affected batch compliance statuses shall be re-evaluated automatically on ingestion.
- Laboratory assay results shall be ingested directly from accredited laboratory APIs wherever available; manual entry shall be permitted only as a fallback, with a 'manual entry' flag applied to the record and four-eyes approval required.
- CBP ACE data shall be used to cross-validate export and import clearance event data; discrepancies shall be flagged for review.

8.4 Event Schema Versioning

- Each custody event record shall store the schema version active at the time of submission (FR-009). The current schema version shall be an independently managed, version-controlled artefact.
- When an event type schema is updated, existing historical records created under the prior schema shall remain valid and retrievable under the old schema version. The platform shall not attempt to retroactively populate new fields on historical records.
- New schema versions shall be deployed via a controlled migration process including: backward-compatibility verification, test scenarios against historical data, and Compliance Lead sign-off.
- The Compliance Rule Engine shall be capable of evaluating a custody event against the compliance rules applicable to its schema version at the time of submission.

8.5 Concurrency and Conflict Resolution

- The platform shall implement optimistic concurrency control for all write operations on shared records. A write that conflicts with a concurrent write shall return an HTTP 409 Conflict response with sufficient context for the requesting user to resolve the conflict.
- The compliance rule engine shall process batches in an ordered, serialised sequence per batch identifier. Concurrent rule evaluations on the same batch shall not produce inconsistent compliance assessment records.
- The four-eyes approval workflow shall prevent a second approver from approving a record that has been modified since the first approver reviewed it. A modified record shall restart the approval workflow.

9. Integration Requirements

The platform shall support integration with the following external systems. Every integration shall define: data format, refresh frequency, failure behaviour, fallback state, and minimum API version supported.

System Type	Direction	Frequency	Failure Behaviour & Fallback
Accredited Laboratories (SGS, ALS, Bureau Veritas, US-based equivalents)	Inbound	Polled every 15 min	On failure: staleness alert if no update within 2 hours. Manual entry fallback with 'manual-entry' flag and four-eyes approval required.
RMI RMAP Smelter List	Inbound	On publication (~quarterly)	On failure: retry 3x with exponential backoff. If unavailable after 24 hours, alert Compliance Officer. Existing list version remains active.
CBP ACE (US Customs and Border Protection)	Inbound/Outbound	Event-driven (export/import events)	On failure: custody event stored with 'customs-pending' flag. Cross-validation deferred. Manual reconciliation workflow available to Compliance Officer.
IoT Tracking Devices (Tive, Roambee)	Inbound	Real-time via IoT Hub	On connectivity loss: last-known position retained. Alert if no update within reporting interval. 'tracking-gap' flag applied.
Blockchain Anchoring (Minespider / Fabric)	Outbound	Event-driven (every write)	On failure: 'anchor-pending' status. Retry every 5 minutes. Alert after 1 hour unanchored. Event is not rejected.
Email Notification (Azure Communication Services)	Outbound	Event-driven (alerts)	On failure: retry 3x over 24 hours. Delivery failure logged. Escalation contact notified via webhook if configured.
Partner API (Enterprise tenants)	Inbound	On demand	On authentication failure: HTTP 401. On rate limit breach: HTTP 429 with retry-after header. On service unavailability: HTTP 503 with estimated recovery time.

10. Delivery Phasing

Phase	Scope	Exit Criteria
Phase 1	Core custody event capture for all 12 event types; compliance checking for DFARS 7008, DFARS 7009, RMAP, and OECD DDG; DFARS Declaration Package and Material Passport generation; supplier and buyer portals; document management (FR-030 to FR-038); basic tamper-evident anchoring; laboratory and smelter list integrations; offline event capture (FR-055 to FR-057).	At least three suppliers and one buyer live with real batch data; a DFARS Declaration Package has been independently verified by a compliance officer; all mandatory event fields are validated at submission; document versioning and four-eyes approval workflows operational.
Phase 2	Remaining compliance frameworks (Section 232, Form SD, Labour, Environmental, Custom Rules); all five document package types; auditor portal; in-transit IoT integration; CBP ACE customs integration; search and retrieval (FR-039 to FR-043); Partner API (FR-049 to FR-054); compliance rule authoring UI	Full audit dossier retrievable within 4 business hours for any batch; all nine compliance frameworks operational; Partner API live and documented; search returning results within 3 seconds (p95); independent penetration test completed with no

Phase	Scope	Exit Criteria
	(FR-044 to FR-048); incident response capability (FR-060 to FR-064); enhanced reporting; scalability to full production volumes.	critical findings outstanding; platform processing >= 100 batches per month.

11. Constraints and Assumptions

11.1 Constraints

- The platform must operate within the legal and regulatory framework of the United States federal government procurement rules (DFARS) and applicable US trade law (Section 232).
- Supplier participation requires acceptance of a data-sharing agreement defining what data is visible to buyers and auditors; the platform must enforce these visibility boundaries technically.
- The platform must not store the full content of classified or export-controlled documents; references and hashes only shall be stored where applicable.
- All data must be stored within United States Azure regions (US East primary, US West secondary). No data may be written to non-US regions.
- The compliance rule authoring format (FR-044) must be agreed between the CTO and Compliance Lead before Week 9 of the project schedule.
- US state privacy law obligations applicable to the platform's tenant base must be confirmed by legal counsel before go-live. The Compliance Lead shall provide a written summary of applicable state laws within 30 days of appointment. **ACTION (CRITICAL — C2):** Legal counsel engagement must be initiated within 14 days of spec sign-off. A written legal opinion on applicable US state privacy statutes (CCPA, CPRA, VCDPA, TDPSA, and equivalents) must be received before Phase 2 go-live. FR-037, FR-064, and AC-07 are untestable without this opinion. This is a pre-APPROVED-status action jointly owned by the CTO and Compliance Lead.

11.2 Assumptions

- Suppliers are assumed to have internet access for normal operation. Offline mode (Section 5.11) provides degraded-mode operation for intermittent connectivity scenarios.
- Accredited laboratories are assumed to provide digital results in structured formats; the platform will define a minimum required format as part of integration specifications.
- Regulatory frameworks referenced in this specification are those current as of March 2026; the compliance rule engine must be designed to accommodate regulatory updates without requiring platform redevelopment.
- The external immutable ledger provider (Minespider Phase 1) is assumed to offer a publicly accessible verification API with a defined SLA.
- The Minespider contract, including SLA, API version commitment, and public verification endpoint availability guarantee, is assumed to be signed before Week 7 of the project schedule. A GDPR data processing agreement is not required given the US-only scope.
- **D4-CONTINGENCY (M6):** If the Minespider contract is not executed by the end of Week 5, the CTO shall activate the contingency anchoring provider. Preference order: (1) Azure Confidential Ledger; (2) Chainpoint. The contingency provider must offer a publicly accessible verification API equivalent to FR-019 requirements. The anchoring provider metadata field (FR-020) ensures historical hashes remain independently verifiable regardless of provider.
- CBP ACE is the sole customs integration required. No non-US customs system integration is in scope.

12. Success Criteria and Acceptance

#	Acceptance Criterion
AC-01	A DFARS Declaration Package generated by the platform has been reviewed and accepted by a qualified US government contractor compliance officer as submission-ready.
AC-02	A complete audit dossier for a Phase 2 batch has been independently verified by an external auditor, including blockchain proof verification, within the 4-business-hour SLA.

#	Acceptance Criterion
AC-03	~~The compliance rule engine has been validated against at least 20 historical batch scenarios (10 compliant, 10 non-compliant), covering all nine frameworks, with 100% accuracy against expert-reviewed expected outcomes.~~ The compliance rule engine has been validated against a minimum of 20 historical batch scenarios per framework (10 compliant, 10 non-compliant per framework), covering all nine named frameworks. Required edge cases per framework: split batch, out-of-order event, disputed record, and expired certificate. Acceptance threshold: 100% accuracy for DFARS 7008/7009; 95% or above for all other frameworks with documented exceptions approved by the Compliance Lead. A partial acceptance record with a remediation plan and re-test date must be produced if any framework falls below threshold.
AC-04	A penetration test conducted by an independent third party has found no critical or high-severity findings outstanding.
AC-05	Three suppliers have onboarded and submitted real custody events for at least one complete batch lifecycle from extraction to delivery.
AC-06	All non-functional requirements defined in Section 6 have been verified by independent testing under realistic load conditions.
AC-07	A data retention and user data correction process has been demonstrated to satisfy applicable US privacy law obligations without compromising the integrity of the custody chain record.
AC-08	The Partner API has been demonstrated operational for at least one Enterprise tenant integration, with a successful end-to-end read of compliance status data via the documented API.
AC-09	The compliance rule authoring workflow has been demonstrated: a Compliance Lead has deployed a new rule set version via the platform UI without a code deployment, and the change has taken effect on subsequent compliance assessments.
AC-10	The offline event capture and synchronisation workflow has been demonstrated: a supplier has captured a custody event offline and the event has been successfully synchronised and processed upon connectivity restoration.
AC-11	A buyer can reconstruct their DFARS compliance record from a platform data export file alone, without requiring access to the live platform.

Test cases for all FR-001 through FR-082 requirements shall be documented in Azure DevOps Test Plans. Each test case must be linked to its FR identifier, assigned an owner, and reviewed by the CTO before the corresponding requirement enters the build queue. Azure DevOps Test Plans is the mandated test management tool. (L3)

13. Glossary

Term	Definition
Batch	A defined quantity of tungsten material with a unique identifier, tracked as a single unit through the custody chain.
CBP ACE	US Customs and Border Protection Automated Commercial Environment — the primary US customs integration for import and export clearance validation.
Chain of Custody	The documented sequence of custody events establishing continuous accountability for a batch from origin to destination.
Covered Country (DFARS)	A country listed under DFARS 252.225-7008 whose minerals are subject to conflict-mineral restrictions.
Custody Event	A structured, timestamped record of an action or state change affecting a batch, as defined by one of the twelve event types in this specification.
DFARS	Defense Federal Acquisition Regulation Supplement — US DoD procurement rules governing conflict minerals. Clauses 252.225-7008 (prime contractors) and 252.225-7009 (sub-contractors) impose distinct obligations and are implemented as separate compliance checks.
Event Schema Version	A versioned definition of the mandatory and optional fields for a given custody event type. Stored alongside each custody event record to support schema evolution without altering historical data.

Term	Definition
Hash / SHA-256	A cryptographic fingerprint of a document or record; used to verify integrity without storing the full content on the ledger. SHA-256 is the minimum algorithm; a documented upgrade path must exist.
Legal Custody Transfer	The transfer of legal title to a tungsten batch from one party to another, as recorded in Event Type 3. Distinct from physical custody transfer, which may occur at a different time.
Material Passport	A summary document accompanying a batch that provides provenance, compliance status, and blockchain verification capability.
OECD DDG	OECD Due Diligence Guidance for Responsible Supply Chains of Minerals from Conflict-Affected and High-Risk Areas.
Physical Custody Transfer	The transfer of physical possession of a tungsten batch from one party to another, as recorded in Event Type 3. Distinct from legal custody transfer.
RMAP	Responsible Minerals Assurance Process — RMI's programme for auditing and listing conformant smelters and refiners.
Rule Set Version	A versioned, immutable instance of the compliance rule logic for a given regulatory framework. Stored alongside each compliance assessment record. Cannot be altered retroactively once deployed.
Section 232	A US trade statute allowing the President to impose tariffs on imports that threaten national security; directly applicable to tungsten derivatives entering the US market.
Smelter	A facility that processes tungsten ore concentrate into refined tungsten product; a key control point in the RMAP framework.
System of Record	The single, authoritative source of truth for a given data domain; the platform is designated as the system of record for all custody events and compliance assessments.
Tamper-Evident Ledger	An external immutable record, such as a blockchain, used to anchor cryptographic hashes of custody events and documents.

14. Escalation and Ownership

Compliance Requirement Class	Primary Owner	Escalation Contact	Response Timeframe
Compliance check failure (active batch)	Compliance Officer	Compliance Lead	Acknowledge within 4 business hours; resolution plan within 24 hours
Certificate expiry warning (30-day)	Compliance Officer	Compliance Lead	Acknowledge within 1 business day; supplier notified within 2 business days
Certificate expiry (expired)	Compliance Lead	CTO + Legal	Immediate acknowledgement; escalation to Legal within 4 hours if batch has active DFARS obligation
Integration staleness alert	Platform Administrator	CTO	Acknowledge within 1 hour; investigation commenced within 2 hours; resolution or manual fallback within 4 hours
Blockchain anchoring failure (>1 hour)	Platform Administrator	CTO	Acknowledge within 30 minutes; resolution or escalation to CTO within 1 hour
Unacknowledged compliance alert (>48 hours)	Compliance Lead	Board Sponsor	Automatic escalation at 48 hours; Board notified if batch has active regulatory submission in flight
Disputed event (>5 business days unresolved)	Compliance Lead	CTO + affected parties	Review meeting within 5 business days of flag; resolution or formal dispute process initiated
User data correction request (US privacy law)	Compliance Officer	Compliance Lead	Acknowledge within 30 days; correction or pseudonymisation completed within 45 days

Compliance Requirement Class	Primary Owner	Escalation Contact	Response Timeframe
Security incident (potential breach)	Platform Administrator	CTO + data protection contact	CTO notified within 1 hour; data protection contact notified within 4 hours; applicable state breach notification obligations met
Manual data entry / override	Compliance Officer (approver)	Compliance Lead	Four-eyes approval required within 1 business day of submission

■ Data Protection Contact Note — M5 (FR-063)

The data protection contact designated under FR-063 is an organisational role, not a platform system role. The designated individual must be reachable within 4 hours of a confirmed or suspected breach at any time. They are not required to have platform login access. The Compliance Lead shall confirm the named individual and their contact details before Phase 1 go-live.

15. Commercial Framework

This section defines the commercial framework for US market operations. These requirements are owned by the Platform Operator and must be resolved before Enterprise sales conversations begin.

15.1 Subscription Tiers

Feature	Starter	Professional	Enterprise
Active Batches	Up to 50/month	Up to 500/month	Unlimited
Users	Up to 10	Up to 100	Unlimited
Compliance Frameworks	DFARS 7008, DFARS 7009, RMAP, OECD DDG	All 9 standard frameworks	All 9 + custom rules
Document Packages	Material Passport only	All 5 package types	All 5 + white-label branding
Data Residency	US East (fixed)	US East or US West	Dedicated US region + BYOK
Partner API	Not included	Read-only API	Full read/write API
Offline Mode	Basic (event queue only)	Full offline capture	Full offline + mobile app
SLA	99.0% availability	99.5% availability	99.9% + dedicated support
Regulatory Update SLA	Best effort (90 days)	30 days after regulatory change effective date	14 days after regulatory change effective date
Support	Community + email	Business hours support	24/7 dedicated support

ACTION (L4): The Platform Operator shall complete an Azure infrastructure cost model and pricing schedule within 60 days of spec sign-off. The output shall be a signed pricing schedule appended to this section. Enterprise sales conversations must not begin until this pricing schedule is signed.

15.2 Regulatory Change Management

FR-065 The Platform Operator shall maintain a regulatory watch function that monitors changes to all ~~nine compliance frameworks~~nine named regulatory frameworks. The Compliance Lead shall be notified of material regulatory changes within 5 business days of official publication.

FR-066 Regulatory change SLAs: Starter — rule update within 90 days; Professional — within 30 days; Enterprise — within 14 days. These SLAs shall be contractually binding for each tier.

FR-067 Rule updates in response to regulatory changes shall be included in the SaaS subscription fee at no additional charge for all tiers.

FR-068 The Platform Operator shall communicate upcoming regulatory changes and planned rule updates to all affected tenants at least 10 business days before the update is applied to production.

15.3 Data Portability and Exit Rights

FR-069 Any tenant shall be able to export a complete archive of their platform data at any time, in JSON + PDF format. The export shall include: all custody events, all compliance assessments, all document hashes, all generated compliance packages, and all audit logs.

FR-070 On tenant offboarding, a full data export (FR-069) shall be provided to the tenant before the soft-delete period begins. The tenant shall have 90 days to confirm receipt before hard deletion proceeds.

FR-071 The data export format shall be documented and published, such that a buyer who migrates to a different compliance platform can demonstrate continuity of their DFARS compliance record from export data alone.

15.4 Support Model

FR-072 Support model per tier: Starter — community forum and email, target response 2 business days. Professional — business hours email and in-platform chat, target response 4 business hours. Enterprise — 24/7 telephone and email, dedicated customer success manager, target response 1 hour for P1 incidents.

FR-073 P1 incident: platform unavailable or compliance package generation failing for an active batch with a DFARS submission deadline within 48 hours. P1 incidents shall be escalated to the CTO within 30 minutes.

FR-074 A public-facing service status page shall display real-time platform availability and any active incidents, updated within 15 minutes of a P1 or P2 incident being declared.

15.5 Supplier Value Proposition

FR-075 Suppliers shall receive a Material Passport for every completed batch at no additional cost, sharable with their own customers as evidence of responsible sourcing provenance.

FR-076 Suppliers shall receive real-time visibility of their own compliance status across all applicable frameworks, including certificate expiry warnings with sufficient notice to renew before expiry.

FR-077 The Supplier Portal shall be available in a mobile-friendly format suitable for use on a smartphone browser with a 3G connection, supporting the offline event capture workflow defined in Section 5.11.

FR-078 Suppliers shall be able to generate a compliance summary report of their own supply chain performance, suitable for use in their own customer and investor reporting.

■ CEO — Review Note

- Section 15.1 pricing tiers require absolute pricing decisions before Enterprise sales conversations begin.
- FR-071 (data portability) must be demonstrated in the acceptance criteria — see AC-11.
- The regulatory change SLAs in FR-066 are commercial commitments that must be resourced. The compliance team must have the capacity to meet the 14-day Enterprise SLA before Enterprise contracts are signed.

16. AI and Automated Intelligence — Position Statement

16.1 Current Position

The platform in its initial delivery (Phase 1 and Phase 2) shall not use AI or machine learning for compliance rule evaluation, anomaly detection, or risk scoring. All compliance assessments shall be produced by deterministic rule logic applied to structured data. This is a deliberate design decision for the following reasons:

- Legal defensibility: DFARS declarations and SEC Form SD filings must be traceable to specific, auditable data points. An AI-generated compliance assessment cannot be defended in a regulatory inquiry without full explainability of the model's decision path.
- Regulatory acceptance: there is no established precedent for AI-generated conflict-mineral compliance assessments being accepted by US government procurement authorities.
- Auditability: the platform's audit dossier must be independently verifiable. A black-box AI component in the compliance pipeline undermines this verifiability.

16.2 Future Roadmap Considerations

The following AI capabilities are candidates for a Phase 3 roadmap, subject to regulatory acceptance, legal review, and CTO recommendation: anomaly detection (advisory flags for human review); predictive compliance forecasting; document intelligence for automated data extraction from supplier-submitted documents.

> ■ *No AI capability shall be introduced into the compliance rule evaluation pipeline without: a written legal opinion on regulatory acceptance, a full explainability audit of the model, and explicit acceptance by the Compliance Lead. AI capabilities shall be advisory supplements to deterministic rule evaluation, not replacements for it.*

17. Open Architecture Decisions

The following decisions require confirmation before Phase 1 build begins.

#	Decision Required	Owner	Status / Implication of Deferral
D1	Confirm US Azure regions: US East as primary, US West as secondary. No other regions permitted given US-only scope.	*CTO*	**RESOLVED by US-only scope — US East / US West is the mandated configuration.**
D2	Confirm Entra External ID vs Azure AD B2C: Microsoft is migrating B2C to Entra External ID. Evaluate GA timeline and feature parity before final identity platform selection.	*CTO*	**OPEN — Identity architecture and MSAL configuration may differ. Delay risks mid-project identity migration. ACTION (C3):** Hard decision deadline Week 2 of project schedule. If Entra External ID GA timeline cannot be confirmed with Microsoft before Week 2, default to Azure AD B2C with a documented migration path. CTO is sole decision owner. This is a pre-build gate: Angular auth, APIM JWT policy, and RBAC enforcement cannot be finalised without this decision.
D3	Define numeric cross-validation tolerances: quantity tolerance (%), date tolerance (days), mass balance threshold (%) for each event type.	*Compliance Lead + Supply Chain Expert*	**RESOLVED (16 March 2026) — Industry-standard defaults defined for all 12 event types per D3-DEFAULTS-v1.0. Values incorporated into FR-008 and stored in compliance-config/tolerance-rules.json. Compliance Lead sign-off required before config is promoted to production.**
D4	Confirm Minespider contract terms: SLA, API version commitment, and public verification endpoint availability guarantee. Note: GDPR data processing agreement is no longer required given US-only scope.	*CTO + Legal*	**OPEN — If Minespider cannot guarantee the public verification endpoint, an alternative Phase 1 anchoring provider must be identified before build. ACTION (D4-CONTINGENCY — H2):** If Minespider contract is not signed by Week 5, activate contingency provider — Azure Confidential Ledger (preferred) or Chainpoint. Legal counsel must confirm before Phase 1 go-live whether a US sub-processor agreement is required with Minespider under applicable US state privacy law (particularly CCPA if California-based tenants are in scope).
D5	Confirm Enterprise tenant BYOK key management process: who holds the master key, rotation schedule, and data recovery process if a tenant deletes their key.	*CTO + Legal + Compliance Lead*	**OPEN — BYOK cannot be offered to Enterprise tenants until the key escrow and recovery process is legally defined. ACTION (H3):** D5 must be resolved before any Enterprise sales conversation begins. CTO and Legal to schedule a key management design review within 30 days of spec sign-off. Enterprise tier shall not be marketed or sold until D5 is resolved and documented.

18. Expert Review Summary

The following table summarises all expert and executive review points from v1.0, v2.0, v2.1, v2.2, and v2.3. All open RA-XX items must be resolved before this document is promoted from DRAFT to APPROVED status.

Ref	Reviewer	Point	Status (v2.3)
RA-01	Internal Audit	Escalation paths and ownership must be explicitly defined.	RESOLVED — Section 14 added.
RA-02	Internal Audit	Four-eyes approval required for all manual data entries.	RESOLVED — FR-013, FR-033, FR-057.
RA-03	Internal Audit	RMAP re-evaluation change log must be retained and auditable.	RESOLVED — FR-014 and FR-029.
RA-04	Computer Scientist	All functional requirements must carry unique, traceable identifiers.	RESOLVED — FR-001 through FR-078.
RA-05	Computer Scientist	Edge cases (split batches, out-of-order events, duplicates) must be specified.	RESOLVED — FR-002, FR-004, FR-005, FR-006.
RA-06	Computer Scientist	Integration failure behaviour must be defined per integration.	RESOLVED — Section 9 updated with failure behaviour column.
RA-07	Compliance & Legal	DFARS 252.225-7008 and -7009 must be distinguished.	RESOLVED — Two separate rows in Section 5.2; FR-011.
RA-08	Compliance & Legal	OECD version control requirement must be formalised.	RESOLVED — FR-010.
RA-09	Security Expert	Data classification schema required.	RESOLVED — Section 7.3.
RA-10	Security Expert	Rate-limiting on public verification endpoint.	RESOLVED — NFR-09.
RA-11	Supply Chain Expert	Split-batch handling must be explicitly specified.	RESOLVED — FR-005.
RA-12	Supply Chain Expert	Legal vs physical custody transfer must be disambiguated.	RESOLVED — Event Type 3 updated; Section 13 Glossary.
RA-13	CTO Critique	FR identifiers absent.	RESOLVED — FR-001 through FR-078.
RA-14	CTO Critique	Compliance rule authoring model undefined.	RESOLVED — Section 5.9. Rule authoring format to be agreed CTO + Compliance Lead before W9.
RA-15	CTO Critique	Event schema versioning unaddressed.	RESOLVED — FR-009; Section 8.4.
RA-16	CTO Critique	Document management absent as a functional area.	RESOLVED — Section 5.7 (FR-030 to FR-038).
RA-17	CTO Critique	Search and retrieval not specified.	RESOLVED — Section 5.8 (FR-039 to FR-043).
RA-18	CTO Critique	Partner API had no functional requirements.	RESOLVED — Section 5.10 (FR-049 to FR-054).
RA-19	CTO Critique	Offline and degraded-mode operation unspecified.	RESOLVED — Section 5.11 (FR-055 to FR-059).
RA-20	CTO Critique	Concurrency and conflict resolution unaddressed.	RESOLVED — Section 8.5.
RA-21	CEO Critique	No commercial model.	RESOLVED — Section 15 (FR-065 to FR-078).
RA-22	CEO Critique	No AI position statement.	RESOLVED — Section 16.
RA-23	CEO Critique	Auditor first-class user experience undefined.	RESOLVED — FR-016, FR-043, Section 7.1.

Ref	Reviewer	Point	Status (v2.3)
RA-24	CEO/CTO Critique	GDPR erasure-vs-immutability architecturally resolved but legally unvalidated.	RESOLVED BY SCOPE — US-only scope removes GDPR obligations. Data correction workflow (FR-037, FR-064) scoped to applicable US privacy law. US state privacy law confirmation required from legal counsel before go-live.
RA-25	CEO/CTO Critique	Incident response and breach notification absent.	RESOLVED — Section 7.4 (FR-060 to FR-064), simplified for US obligations.
RA-26	v2.1 Scope Change	EU data residency, GDPR DPA for Minespider, ILO international labour standards, and multilingual document storage removed from scope.	RESOLVED BY SCOPE — All references removed. Labour compliance scoped to US federal/state law. NFR-13 added for US data residency mandate. D4 updated to remove GDPR DPA requirement from Minespider contract.

> ■ *v2.3 DRAFT Status: All RA items are resolved or addressed. Remaining pre-APPROVED actions: (1) legal counsel engagement on US state privacy law (C2, Section 11.1, 14-day deadline from sign-off); (2) CTO decision on CMMC 2.0 C3PAO vs self-attestation (FR-080, Week 4 deadline); (3) D2 identity platform decision (C3, Week 2 deadline); (4) D5 BYOK key management design review (H3, 30-day deadline); (5) Compliance Lead sign-off on D3 tolerance values before config is promoted to production.*

Sign-Off

This document takes effect when signed by the following roles. Promotion to APPROVED requires: CTO confirmation that the rule authoring format (FR-044) is agreed, legal counsel confirmation of applicable US state privacy laws, Compliance Lead sign-off on D3 tolerance values (D3-DEFAULTS-v1.0), and sign-off by all parties below.

Role	Name	Signature & Date
Board Sponsor		
Compliance Lead		
Internal Audit Representative		
CTO		